TECHNICAL SPECIFICATION & SYSTEM ARCHITECTURE

Staff Management Portal – Enterprise Workforce Platform

Comprehensive engineering report covering full-stack system architecture, company-isolated workspace tenancy, dual-provider authentication (Stateless JWT + Google OAuth 2.0 / OIDC), Administrator role-based access control (Admin RBAC), relational database schemas, automated role migration, and interactive OpenAPI / Swagger 3.0 specification.

Author / Candidate	Sudhir Kumar (GitHub: sudhirkr2003)	**GitHub Repository**	staff-management-portal
Live Frontend UI	http://localhost:3000 / Web Client	**Live Backend API**	http://localhost:8080 / REST API
Interactive Swagger UI	`http://localhost:8080/swagger-ui/index.html`	**OpenAPI 3.0 JSON Docs**	`http://localhost:8080/v3/api-docs`
Technology Stack	Spring Boot 3.3.5 (Java 17) + React 18 + MySQL 8	**Specification Date**	05 November 2026

1. Project Overview & Core Capabilities

The **Staff Management Portal** is a high-performance enterprise employee administration and workforce governance platform. Built with a strict separation of concerns, the system enables corporate administrators to register their organization, establish an isolated company workspace, and manage employee records throughout their entire employment lifecycle.

1.1 Architectural Pillars

- **Strict Admin Tenancy (1 Admin = 1 Company = All Employees)**: Each unique email registration establishes an independent Administrator account. Every administrator owns exactly one company workspace, and all employee records belong exclusively to that company. Strict backend ownership checks prevent cross-tenant data leakage.
- **Dual-Provider Secure Authentication**: Integrated support for email/password registration backed by 6-digit cryptographic OTP delivery, along with Google OAuth 2.0 / OpenID Connect Single Sign-On (SSO). Both authentication flows automatically provision authenticated accounts with the ADMIN role.
- **Full-Lifecycle Employee CRUD**: Comprehensive employee management supporting creation, profile viewing, multi-attribute updates, salary adjustment, department reassignment, and safe record deletion with confirmation modals.
- **Real-Time Workforce Analytics & Telemetry**: Instant telemetry on total employee headcount, active company departments, overall payroll expenditure, average salary benchmarks, and department staff distribution.
- **Continuous Availability & Keep-Alive Diagnostics**: Dedicated public /api/health endpoint returning service status and ISO timestamps, optimized for continuous cloud monitoring via UptimeRobot to eliminate cold-start delays on cloud containers.
- **Interactive Swagger / OpenAPI 3.0 Documentation**: Native interactive API explorer supporting live execution and Bearer JWT authorization testing.

2. Tech Stack & Architectural Decision Records (ADRs)

Architectural Layer	Technology Selected	Decision Rationale & Benefits
Backend Runtime	Spring Boot 3.3.5 (Java 17 LTS)	Modern Java LTS runtime, strong type safety, declarative transaction management (@Transactional), fast startup, and native JPA persistence.
API Documentation	Springdoc OpenAPI 2.6.0 (Swagger 3)	Auto-generates OpenAPI 3.0 schema and rich interactive Swagger UI supporting Bearer JWT authentication for testing protected endpoints.
Frontend Client	React 18 + Vite 5.4 + CSS	Ultra-fast hot module replacement (HMR), sub-second build times, modular component tree, lightweight bundle (< 350 KB), zero runtime CSS overhead.
Database Engine	MySQL 8.0 Relational DB	Industry-standard relational persistence, ACID guarantees, foreign key integrity constraints, and indexed unique lookups.
Security Framework	Spring Security 6.x + Stateless JWT	Stateless HMAC-SHA256 token verification, BCrypt password hashing (cost factor 10), OAuth2 authorization code grant client, and fine-grained endpoint matchers.
Email Delivery	Spring Mail (JavaMailSender)	Asynchronous delivery of time-limited 6-digit OTP verification codes for new registrations and password recovery.
Health Monitoring	UptimeRobot + /api/health	Automated 5-minute health probe preventing idle cloud container spin-down and ensuring 100% continuous uptime.

3. Relational Database Schema & Data Models

Table Name	Primary Attributes & Types	Constraints, Relations & Indices
`users`	id (BIGINT PK), full_name (VARCHAR 150), email (VARCHAR 150), password (VARCHAR 255), role (VARCHAR 50), google_id (VARCHAR 100), auth_provider (VARCHAR 20), email_verified (BOOLEAN), created_at, updated_at	Primary administrator entity. UNIQUE(email), UNIQUE(google_id). Role enforced as ADMIN via JPA @PrePersist and @PreUpdate lifecycle listeners.
`companies`	id (BIGINT PK), name (VARCHAR 150), industry (VARCHAR 100), business_email (VARCHAR 150), contact_phone (VARCHAR 30), website (VARCHAR 255), owner_id (BIGINT FK), created_at, updated_at	Company workspace entity. UNIQUE(owner_id) enforces strictly 1 company per administrator. Foreign key referencing users(id).
`employees`	id (BIGINT PK), full_name (VARCHAR 150), email (VARCHAR 150), phone (VARCHAR 30), department (VARCHAR 100), designation (VARCHAR 100), salary (DECIMAL 12,2), joining_date (DATE), company_id (BIGINT FK), user_id (BIGINT), created_at, updated_at	Employee records. FK(company_id) -> companies(id). Multi-attribute isolation ensuring queries filter by company_id matching the authenticated admin.
`pending_registrations`	id (BIGINT PK), email (VARCHAR 150), full_name (VARCHAR 150), password (VARCHAR 255), otp_hash (VARCHAR 255), expires_at (DATETIME), resend_available_at (DATETIME), attempts (INT), created_at	Staging store for unverified registrations. UNIQUE(email). OTPs hashed with BCrypt. Expired after 10 minutes.
`password_reset_otps`	id (BIGINT PK), email (VARCHAR 150), otp_hash (VARCHAR 255), expires_at (DATETIME), failed_attempts (INT), created_at	Secure OTP repository for forgotten password recovery. UNIQUE(email). Enforces max attempt thresholds and cooldown timers.

4. Role-Based Access Control (RBAC) & Tenancy Isolation

The application follows an **Admin-Only Single-Tenant Workspace Architecture**. All end-users interacting with the portal are Administrators who manage their respective organizational silos. Regular employees do not log into the administrative portal, guaranteeing that privileged payroll and personnel data remain confidential.

Operational Action	Unauthenticated	Authenticated Admin	Cross-Tenant Admin	Enforcement Mechanism

Register Admin & Request OTP	Permitted	Permitted	N/A	/api/auth/admin/register (Public permitAll)
Verify OTP & Create Account	Permitted	Permitted	N/A	Validates OTP hash, provisions ADMIN role
Google OAuth SSO Sign-In	Permitted	Permitted	N/A	OAuth2 Callback & JWT Token Issuer
Create Company Workspace	Deny (401)	Allowed (1 Company)	Deny (Already Created)	CompanyService enforces 1 company per user
View / Update Own Company	Deny (401)	Full Access	Deny (403)	Ownership check against authenticated JWT Principal
Employee List, Search & Filter	Deny (401)	Own Company Records	Strictly Filtered	employeeRepository.findByCompanyId(adminCompany.getId())
Add / Update Employee Record	Deny (401)	Allowed	Deny (403)	verifyEmployeeOwnership() throws ForbiddenOperationException
Delete Employee Record	Deny (401)	Allowed (Admin Only)	Deny (403)	validateAdmin(principal) + Ownership Verification
Swagger UI & OpenAPI Docs	Permitted	Permitted	Permitted	/swagger-ui/** & /v3/api-docs/** (permitAll)
Health Telemetry Check	Permitted	Permitted	Permitted	/api/health (permitAll)

5. REST API Specification & Swagger Endpoints Catalog

All REST endpoints adhere strictly to standard HTTP status codes, structured JSON envelopes (ApiResponse<T>), and standardized exception mappings.

Method	Endpoint Path	Auth / RBAC	Request Body / Params	Functional Description
GET	`/api/health`	Public	None	Returns service health status, application name, and UTC timestamp for UptimeRobot monitoring.
GET	`/swagger-ui/index.html`	Public	None	Interactive Swagger UI console for exploring and executing API requests.
GET	`/v3/api-docs`	Public	None	OpenAPI 3.0 JSON specification describing all data contracts and operations.
POST	`/api/auth/admin/register`	Public	AdminRegistrationRequest	Initiates registration and dispatches 6-digit verification OTP to the administrator's email.
POST	`/api/auth/admin/verify-otp`	Public	OtpVerificationRequest	Verifies OTP and finalizes creation of the Administrator user account in MySQL.
POST	`/api/auth/admin/resend-otp`	Public	ResendOtpRequest	Generates and delivers a fresh 6-digit registration OTP, respecting rate-limit cooldowns.
POST	`/api/auth/login`	Public	LoginRequest	Authenticates administrator credentials and returns signed JWT access token.
POST	`/api/auth/google/complete-registration`	Public	GoogleRegistrationRequest	Finalizes Google OAuth initial account creation with mandatory password setup.
POST	`/api/auth/google/link-account`	Public	GoogleLinkAccountRequest	Links Google OAuth identity to an existing traditional password account.
GET	`/api/auth/profile`	Bearer JWT (Admin)	None	Retrieves the authenticated administrator's profile information.
PUT	`/api/auth/profile`	Bearer JWT (Admin)	UpdateProfileRequest	Updates the administrator's display name.
POST	`/api/auth/change-password`	Bearer JWT (Admin)	ChangePasswordRequest	Securely changes account password after validating the existing password hash.

POST	`/api/auth/forgot-password`	Public	ForgotPasswordRequest	Sends a 6-digit password reset OTP to registered email address.
POST	`/api/auth/verify-reset-otp`	Public	VerifyResetOtpRequest	Validates password reset OTP and issues a short-lived reset token.
POST	`/api/auth/reset-password`	Public	ResetPasswordRequest	Updates forgotten password using the verified reset authorization token.
POST	`/api/companies`	Bearer JWT (Admin)	CompanyRequest	Registers the administrator's company workspace (one company per admin limit).
GET	`/api/companies/my`	Bearer JWT (Admin)	None	Fetches details of the authenticated administrator's company workspace.
PUT	`/api/companies/my`	Bearer JWT (Admin)	CompanyRequest	Updates company organizational details.
GET	`/api/employees`	Bearer JWT (Admin)	None	Retrieves all employee records scoped exclusively to the administrator's company.
POST	`/api/employees`	Bearer JWT (Admin)	EmployeeRequest	Creates a new employee record associated with the administrator's company workspace.
GET	`/api/employees/{id}`	Bearer JWT (Admin)	Path variable id	Retrieves details of a specific employee, verifying company ownership.
PUT	`/api/employees/{id}`	Bearer JWT (Admin)	EmployeeRequest	Updates employee profile, role, department, salary, or contact information.
DELETE	`/api/employees/{id}`	Bearer JWT (Admin)	Path variable id	Permanently deletes employee record after validating workspace ownership.

6. Security, Authentication & Cryptography

- **Password Hashing**: Passwords are salted and hashed using Spring Security's BCryptPasswordEncoder with a standard strength factor of 10. Passwords are never stored or logged in plaintext.
- **Stateless JWT Issuance**: Signed using HMAC-SHA256 (256-bit secret key). Tokens encapsulate subject ID, authenticated email, and the ADMIN authority claim with a configurable expiration duration (default 24 hours).
- **CORS & CSRF Defense**: Cross-Origin Resource Sharing is enabled with explicit whitelist allowances for HTTP methods (GET, POST, PUT, DELETE, OPTIONS) and request headers. CSRF protection is safely disabled as the backend uses stateless JWT authentication with no session cookies.
- **Automatic Legacy Role Migration**: The AccountRoleMigrationRunner component executes on every Spring Boot startup, seamlessly upgrading any legacy user records to the ADMIN role while preserving all existing company links and employee records.

7. Live Cloud Deployment & Continuous Availability (UptimeRobot)

Continuous Uptime Architecture: Free-tier cloud instances (e.g. Render, Railway) suspend compute containers after 15 minutes of inactivity. The integrated /api/health endpoint is designed to receive automated HTTP GET probes from UptimeRobot every 5 minutes, keeping the container warm and eliminating latency spikes for end-users.

UptimeRobot Field	Recommended Production Setting	Purpose
Monitor Type	HTTP(s)	Standard HTTP health polling
Friendly Name	Staff Management Portal Backend	Dashboard identification
URL / IP	https://<your-backend-domain>/api/health	Target endpoint path
Monitoring Interval	Every 5 minutes	Prevents container inactivity spin-down

Expected HTTP Status	200 OK	Healthy service validation

8. Quick Local Setup & Development Guide

```
# 1. Database Setup (MySQL)
mysql -u root -p
CREATE DATABASE IF NOT EXISTS staff_management_portal;

# 2. Backend Service (Spring Boot 3.3.5)
cd backend
mvn clean compile
mvn spring-boot:run

# Swagger UI will be available at:
# http://localhost:8080/swagger-ui/index.html
# OpenAPI JSON schema at:
# http://localhost:8080/v3/api-docs

# 3. Frontend Client (React 18 + Vite)
cd ../frontend
npm install
npm run dev

# Frontend will be live at:
# http://localhost:3000
```